08 – Risk Monitoring and Review

1. Objective

The objective of this document is to define how risks associated with the Electronic Patient Information System are **monitored and reviewed**, ensuring that risk assessments remain relevant and that implemented controls continue to be effective.

The process helps ensure that risks are continuously monitored after treatment decisions are made and that **new risks or changes to existing risks are identified and addressed in a timely manner**.

2. Scope

This document covers risks associated with the Electronic Patient Information System at the fictional private hospital in Jordan, including:

- Patient information registration and appointment management.
- Medical record storage and retrieval.
- User account and access permission management.
- The system database.
- The cloud hosting environment and related services.
- Security and administrative controls used to treat risks.

The scope is limited to the specified system and does not extend to all hospital systems or operations.

3. Risk Monitoring Methodology

Risks are monitored **continuously or periodically**, depending on their nature and importance, to identify changes in their likelihood or potential impact.

The monitoring process includes:

1. **Tracking risks** recorded in the Risk Register.
2. Monitoring the **implementation status** of treatment actions.
3. Monitoring the performance of security and administrative controls.
4. Reviewing logs, reports, and control evidence.

5. Identifying incidents and issues that may indicate increased risk levels.
6. Reporting identified changes or vulnerabilities.
7. **Updating the Risk Register** when necessary.

Monitoring is not limited to confirming that controls exist. It also includes verifying that they continue to operate and remain effective in reducing risks.

4. Risk Monitoring Indicators

The following indicators are used to monitor risks and related controls:

Monitoring Area	Indicators	Information Source
User Accounts	Unusual login attempts, inactive accounts, and permission changes	System logs and account reviews
Access Permissions	Inappropriate permissions and unauthorized permission changes	Permission records and approval logs
Medical Records	Unusual modifications, deletion attempts, and unjustified access	Access and modification logs
Data Export	Unusual or unauthorized export and download activities	Export logs and access settings
Backups	Backup success and restoration test results	Backup logs and restoration reports
Updates and Vulnerabilities	Identified vulnerabilities and delayed security updates	Vulnerability reports and update records
Malware	Security alerts and malware infection attempts	Protection software logs and alerts
Cloud Services	Service interruptions, availability indicators, and infrastructure alerts	Cloud Service Provider reports
Security Events	Unusual activities, security incidents, and incident response time	Event logs and incident reports

Indicators must be selected according to the nature of each risk and its related controls. The availability of monitoring tools and information sources must be verified rather than assumed.

5. Monitoring and Review Frequency

Monitoring and review frequencies are determined according to risk levels and control characteristics.

Activity	Proposed Frequency
Monitoring security alerts and events	Continuous, if monitoring tools are available
Reviewing login logs and unusual activities	Weekly
Reviewing user accounts and access permissions	Every three months
Reviewing medical record access and modification logs	Monthly
Reviewing backup logs	Daily
Testing backup restoration	Every three months
Reviewing updates and security vulnerabilities	Monthly and when important security updates are released
Reviewing Cloud Service Provider reports	Monthly and following an outage or incident
Reviewing the complete Risk Register	Every three months
Reviewing treatment actions	According to implementation deadlines and when significant changes occur

These frequencies represent **proposed monitoring intervals** for the project and may be adjusted according to risk levels, available resources, and the system's actual capabilities.

6. Risk Review

Risk review aims to ensure that previous assessments and decisions remain appropriate for the current system environment.

The review process includes:

1. Reviewing each risk description, its causes, and associated scenarios.
2. Verifying that the assets and functions related to the risk still exist.
3. Reviewing potential threats and vulnerabilities.
4. Checking the status of controls associated with the risk.
5. Reviewing control implementation evidence and effectiveness verification results.
6. Reassessing the **likelihood and impact** when new information or significant changes arise.
7. Comparing the **residual risk level** with approved risk tolerance limits.
8. Updating treatment decisions when necessary.

Any changes to risk levels must be supported by available information and evidence. A risk level must not be reduced simply because a treatment action has been implemented.

7. Event-Driven Review

In addition to periodic reviews, a risk review must be conducted whenever a change or incident may affect risk levels.

Situations requiring a review include:

- A security incident or suspected security breach.
- Unauthorized access to patient information.
- Unauthorized modification or deletion of medical records.
- Discovery of a new vulnerability affecting the system or one of its components.
- Backup failure or inability to restore data.
- Significant interruption of cloud services.
- Changes to the Cloud Service Provider or service agreement.
- Addition of a new system function or a significant system modification.
- Changes to user permissions or responsibilities of involved parties.
- Discovery of an ineffective security or administrative control.
- New threats or information affecting previous risk assessments.

When any of these situations occurs, the affected risks must be identified, their assessments reviewed, and appropriate actions taken according to their risk levels.

8. Monitoring and Review Responsibilities

Monitoring and review responsibilities are distributed among the parties involved with the system as follows:

Party	Responsibilities
Hospital Management	**Oversee risk monitoring**, review reports, and make decisions regarding treatment and risk acceptance within its authority.
System Administrator	Monitor technical logs and alerts, review accounts and permissions, monitor technical controls, and report incidents and technical issues.
Doctors	Report unjustified access to medical records, incorrect modifications, and issues related to system usage.
Registration Staff	Report errors or unusual activities related to patient information and appointments.

Cloud Service Provider	Provide availability and incident reports for hosted services and address issues within its responsibilities under the service agreement.

Hospital Management remains responsible for overall risk oversight, even when technical monitoring activities are assigned to the System Administrator or Cloud Service Provider.

9. Reporting and Escalation

Risks, incidents, and observations that may affect the system must be reported to the responsible party according to their nature and importance.

The reporting and escalation process follows these steps:

1. **Identify** the risk, incident, or observation.
2. Document the available information.
3. Report the situation to the responsible system authority or relevant party.
4. Assess its potential impact on **Confidentiality, Integrity, and Availability (CIA)**.
5. **Escalate significant cases** to Hospital Management.
6. Take appropriate actions to reduce the impact and address the cause.
7. Document the actions taken and their results.
8. Review affected risks and update the Risk Register when necessary.

Incidents threatening patient information confidentiality, medical record integrity, or system availability must receive priority in reporting and response.

10. Documentation

Monitoring and review results must be documented to maintain records that can support decisions and the evaluation of risk management effectiveness.

The documentation should include:

- Monitoring or review date.
- Risk or control reviewed.
- Responsible person or party.
- Information and evidence reviewed.
- Findings and observations.
- Changes in risk levels.

- Required corrective or additional actions.
- Party responsible for following up on actions.
- Target date for closing observations.
- Implementation status and verification results.

Monitoring and review results must be retained within project documentation and the Risk Register to enable **traceability of changes, decisions, and actions**.

11. Risk Register Update

The **Risk Register** must be updated whenever new information or changes affect existing risks or their treatment actions.

Possible updates include:

- Adding new risks.
- Modifying existing risk descriptions or causes.
- Updating likelihood or impact ratings.
- Updating residual risk levels.
- Updating treatment implementation status.
- Updating control status or effectiveness.
- Documenting risk acceptance decisions or additional treatment actions.
- Recording the review date and responsible party.

Previous information and decisions should be retained when necessary to allow the organization to **track how risks evolve and understand why assessments change**.

12. Monitoring and Review Outputs

Expected outputs of the monitoring and review process include:

- **Periodic risk status reports**.
- Control review and effectiveness results.
- Documentation of security incidents and observations.
- Identification of new or changing risks.
- Updated residual risk levels.
- Identification of corrective or additional treatment actions.
- Updated Risk Register.
- Information supporting Hospital Management's risk-related decisions.

13. Continuous Improvement

The results of risk monitoring and review serve as **inputs to the Continuous Improvement process**.

When ineffective controls, new risks, or recurring incidents are identified, their causes must be analyzed and appropriate actions determined to prevent recurrence and improve risk management.

This process ensures that risk management is not a one-time activity but an **ongoing process that evolves with changes to the system, threats, and controls**.